

PENETRATION TESTING REPORT

Mediroza General Hospital

Web Application Security Assessment

Prepared by: Kemar Goulbourne

Cybersecurity Mentor: Waqas Karim, CCIE

Organisation: Networkwalks

Batch: B082 | Week 4 Capstone Project

Target: Mediroza General Hospital

Classification: Confidential

1. Executive Summary

I was assigned to conduct a controlled black-box penetration test against the web application environment of Mediroza General Hospital. The assessment was performed as part of the Networkwalks B082 cybersecurity capstone exercise and was intended to identify security weaknesses, demonstrate their potential impact, and provide recommendations for improving the security posture of the organisation.

During the assessment, multiple vulnerabilities were identified across the web application and its supporting files. The findings included username enumeration, weaknesses in the authentication mechanism, insufficient protection of confidential PDF reports, weak document passwords, sensitive information stored within PDF metadata, directory listing on a legacy folder, and exposure of a historical database backup.

The most significant finding was the exposure of a database backup through a publicly accessible legacy directory. The backup contained staff information, including job titles, departments and salaries, as well as shareholder information including ownership percentages and share classes.

The assessment also demonstrated how seemingly minor reconnaissance information can be combined to reveal a larger security problem. Information identified in PDF metadata pointed toward the `/old` directory, which had also been identified during earlier reconnaissance.

Overall Risk Rating: CRITICAL — Immediate remediation is recommended.

2. Scope and Methodology

2.1 Scope

The assessment focused on the Mediroza General Hospital web application and resources identified during the authorized educational exercise.

The assessment considered:

- Publicly accessible web pages
- Authentication functionality
- Document-access mechanisms
- PDF files supplied by the application
- Publicly exposed directories
- Metadata contained within authorized assessment files
- The database backup identified during the exercise

Activities outside the agreed assessment scope were excluded.

2.2 Methodology

A structured black-box penetration-testing methodology was followed consisting of four main phases.

Reconnaissance

Information was gathered from publicly accessible application resources and files. Particular attention was given to directories, document metadata and information that could reveal additional resources.

Vulnerability Identification

The application's responses and configuration were examined to identify weaknesses involving authentication, information disclosure, file access and server configuration.

Controlled Validation

Identified weaknesses were validated within the authorized laboratory environment to determine their potential impact.

Documentation

Evidence was recorded and findings were documented together with their associated risks and recommended remediation measures.

2.3 Tools Used

The assessment made use of tools and resources appropriate to the laboratory exercise, including:

- **curl** — for examining HTTP responses
- **Browser Developer Tools** — for inspecting application behaviour
- **ExifTool** — for examining PDF metadata
- **qpdf** — for authorized PDF processing
- **wget** — for retrieving assessment files
- **ChatGPT** — for converting raw SQL data into readable tables

3. Findings and Proof of Exploitation

3.1 Summary Table

#	Vulnerability	Location	Risk
1	Username Enumeration	Patient login page	Medium
2	Authentication / SQL Injection Weakness	Patient login page	Critical
3	Confidential PDF Reports Accessible	Patient reports area	High
4	Weak PDF Password Protection	Patient report files	High
5	Sensitive Metadata in PDF	Patient report 3	Medium
6	Forgotten Backup Folder / Directory Listing	/old/	Critical
7	Confidential Staff and Shareholder Data in Backup	Database backup	Critical

3.2 Finding 1 — Username Enumeration

Risk Rating: Medium

Location: Patient login page

Description

Username enumeration occurs when an application provides different responses depending on whether a supplied username exists.

During testing, the login mechanism returned distinguishable responses for different authentication failures. This behaviour allowed the validity of usernames to be determined.

A secure authentication system should provide a generic response for failed authentication attempts rather than revealing whether the username or password was incorrect.

Impact

An attacker could use the different responses to identify valid accounts. This information could then be used as a starting point for further attacks against the authentication system.

Recommendation

The application should return a single generic message for all failed authentication attempts, such as:

"Invalid credentials. Please try again."

Rate limiting and account-protection mechanisms should also be implemented.

3.3 Finding 2 — Authentication / SQL Injection Weakness

Risk Rating: Critical

Location: Patient login page

Description

The authentication mechanism was found to improperly handle user-supplied input. Testing demonstrated behaviour consistent with SQL injection.

SQL injection occurs when untrusted input is incorporated into a database query without appropriate parameterisation. This can allow input to alter the intended database query.

Impact

The weakness could allow an attacker to bypass normal authentication controls and obtain access to functionality intended only for authenticated users.

This finding is particularly serious because the affected application provides access to confidential patient documents.

Evidence

The assessment produced a database-related error when specially crafted input was supplied to the authentication form. This indicated that application input was being incorporated into a database query without sufficient protection.

Recommendation

The application should:

1. Use parameterised queries or prepared statements.
 2. Validate and sanitise input.
 3. Avoid displaying database errors to users.
 4. Use secure authentication mechanisms.
 5. Implement logging and monitoring for suspicious authentication requests.
-

3.4 Finding 3 — Confidential PDF Reports Accessible

Risk Rating: High

Location: Patient reports area

Description

Following validation of the authentication weakness within the controlled assessment, confidential PDF reports were found to be accessible through the patient portal.

These reports represented sensitive medical documents and therefore require strong access controls.

Impact

Unauthorized access to medical documents could result in serious privacy violations and reputational, legal and regulatory consequences for the organisation.

Recommendation

The application should enforce server-side authorization for every document request.

PDF files should not be directly accessible through predictable public URLs. The server should verify that the authenticated user is authorized to access the requested document before returning it.

3.5 Finding 4 — Weak PDF Password Protection

Risk Rating: High

Location: Patient report files

Description

The assessment identified weak password protection on the PDF documents.

Although the files were encrypted, the protection was insufficient because weak passwords can significantly reduce the effectiveness of document encryption.

Impact

An attacker who obtains encrypted documents may be able to recover weak passwords using automated password-guessing techniques.

This means that encryption alone does not provide adequate protection when weak passwords are used.

Recommendation

The organisation should:

- Use strong, randomly generated passwords where document passwords are required.
 - Avoid common passwords and predictable patterns.
 - Use appropriate modern encryption.
 - Prefer application-level authorization over relying solely on PDF passwords.
 - Ensure sensitive documents are stored securely outside publicly accessible directories.
-

3.6 Finding 5 — Sensitive Metadata in Patient PDF

Risk Rating: Medium

Location: Patient report 3

Description

PDF documents may contain metadata that is not immediately visible when the document is opened normally. Metadata can include information such as the author, software used to create the document, creation information and comments.

During the assessment, metadata associated with the authorized report contained the following relevant information:

Metadata Field	Finding
Author	j.malik
Comments	Reference to a database backup being moved to /old

This information was significant because it provided an internal operational clue about the location of a historical backup.

Impact

Metadata disclosure can reveal internal usernames, staff identifiers, software information, directory names and operational notes.

In this case, the metadata helped connect the document to the legacy /old directory.

Recommendation

The organisation should remove unnecessary metadata before distributing documents outside the organisation.

Internal comments, staff identifiers and operational notes should never be embedded in documents intended for users.

3.7 Finding 6 — Forgotten Backup Folder with Directory Listing Enabled

Risk Rating: Critical

Location: /old/

Description

The /old/ directory was identified as a legacy directory with directory listing enabled.

Directory listing allows a web server to display the contents of a directory when no index page is present.

The directory exposed a historical database backup:

mediroza_db_backup_2019.sql

The /old location was particularly significant because it had previously been identified during reconnaissance and was subsequently confirmed by the metadata discovered in Finding 5.

Evidence

The reconnaissance chain was:

```
PDF Metadata
  |
  v
Reference to /old
  |
  v
Previously identified through reconnaissance
  |
  v
Legacy directory
  |
  v
Database backup exposed
```

Impact

Public exposure of a database backup can bypass application-level security controls and expose large quantities of information.

A database backup may contain employee records, business information, authentication information and other sensitive data.

Recommendation

The organisation should:

1. Disable directory listing.
2. Remove the exposed backup from the web root.
3. Store backups outside publicly accessible directories.
4. Apply strict access controls to backup storage.
5. Regularly scan web directories for forgotten backup files.
6. Establish a formal backup-retention and storage policy.

3.8 Finding 7 — Confidential Staff Salaries and Shareholder Data in Plain Text

Risk Rating: Critical

Location: mediroza_db_backup_2019.sql

Description

The database backup contained sensitive organisational information in readable SQL format.

The supplied `staff` data included employee names, job titles, departments and monthly salaries. The `shareholders` data contained shareholder names, ownership percentages and share classes.

The following tables summarize the relevant assessment data.

Staff Information

#	Name	Job Title	Department	Monthly Salary
1	Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	R138,000
2	Sarah Botha	Chief Financial Officer	Finance	R152,000
3	Dr. Johan van der Merwe	Medical Director	Management	R160,000
4	Dr. Anita Naicker	Consultant Cardiologist	Cardiology	R132,000
5	Dr. Ahmed Kara	Consultant Physician	Internal Medicine	R128,000
6	Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	R74,000
7	Michael Roberts	HR Director	Human Resources	R96,000
8	Susan Pretorius	HR Officer	Human Resources	R32,000
9	Jameel Malik	IT Systems Administrator	IT	R58,000
10	Thabo Molefe	Network Engineer	IT	R46,000
11	Nomvula Khumalo	Registered Nurse	Emergency & Trauma	R34,000
12	Lerato Mokoena	Registered Nurse	Pediatrics	R33,000
13	Bongani Ndlovu	Registered Nurse	Cardiology	R35,000
14	Zanele Mahlangu	Nursing Sister	Theatre	R42,000
15	Kagiso Sithole	Pharmacist	Pharmacy	R61,000
16	Naledi Zulu	Pharmacy Assistant	Pharmacy	R26,000
17	Themba Nkosi	Radiographer	Radiology	R44,000
18	Palesa Radebe	Radiographer	Radiology	R43,000
19	Deepak Pillay	Lab Technologist	Diagnostics Lab	R41,000
20	Kavitha Govender	Lab Technician	Diagnostics Lab	R35,000
21	Dr. Suresh Moodley	Consultant Radiologist	Radiology	R130,000

#	Name	Job Title	Department	Monthly Salary
22	Dr. Fatima Patel	Pediatrician	Pediatrics	R118,000
23	Nisha Singh	Physiotherapist	Rehabilitation	R48,000
24	Dr. Vikram Chetty	Anaesthetist	Theatre	R135,000
25	David Smith	Facilities Manager	Operations	R52,000
26	Karen O'Connor	Billing Administrator	Finance	R29,000
27	James Wilson	Security Supervisor	Operations	R27,000
28	Linda Fourie	Receptionist	Front Office	R19,000
29	Peter van Wyk	Procurement Officer	Supply Chain	R38,000
30	Andile Mbeki	Ward Clerk	Administration	R21,000

Shareholder Information

#	Shareholder Name	Share Percentage	Share Class
1	Dr. Rajesh Naidoo	18.0%	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15.0%	Ordinary
3	Dr. Johan van der Merwe	12.0%	Ordinary
4	Reddy Family Trust	11.0%	Ordinary
5	Thabo Molefe	10.0%	Ordinary
6	Sarah Botha	9.0%	Ordinary
7	Dr. Ahmed Kara	8.0%	Preferential
8	Naledi Zulu	7.0%	Ordinary
9	Michael Roberts	6.0%	Ordinary
10	Dr. Vikram Chetty	4.0%	Preferential

The shareholder percentages represented in the supplied data total **100%**.

Correlation with Finding 5

The metadata identifier `j.malik` corresponds to the staff record for **Jameel Malik**, whose listed position is **IT Systems Administrator** in the IT department.

This correlation demonstrates how information from different sources can be connected during reconnaissance.

Impact

The exposure of staff salary and corporate ownership information could lead to:

- Privacy violations
- Social-engineering opportunities
- Targeted attacks against employees
- Disclosure of confidential business information
- Reputational damage
- Potential legal or regulatory consequences

Recommendation

Database backups must never be stored in publicly accessible web directories.

Backups should be:

- Stored outside the web root.
- Access-controlled.
- Encrypted at rest.
- Properly monitored.
- Subject to defined retention policies.
- Regularly audited for accidental exposure.

4. Full Attack Chain Summary

The assessment demonstrated how multiple weaknesses could be connected into a larger security chain.

Step 1 — Initial Reconnaissance

Publicly accessible application resources revealed information about directories and application functionality.

Step 2 — Authentication Weakness

The login mechanism disclosed information about account validity and demonstrated inadequate handling of user input.

Step 3 — Access to Confidential Documents

The authentication weakness could be used within the controlled assessment to reach the patient-report area.

Step 4 — PDF Protection Weakness

The assessment demonstrated that the PDF password protection was not sufficiently strong.

Step 5 — Metadata Discovery

Metadata within one authorized PDF contained an internal identifier and a reference to `/old`.

Step 6 — Legacy Directory Exposure

The `/old` directory had directory listing enabled and exposed a historical database backup.

Step 7 — Database Information Exposure

The backup contained staff salary information and shareholder ownership information.

Step 8 — Information Correlation

The `j.malik` identifier in the PDF metadata corresponded with Jameel Malik in the staff table, completing the reconnaissance chain.

5. Recommendations and Remediation

5.1 Fix Username Enumeration

The login system should return the same generic error message regardless of whether the username or password is incorrect.

Rate limiting and account-monitoring controls should also be implemented.

5.2 Fix SQL Injection

All database queries involving user input should use parameterised queries or prepared statements.

Input should never be directly concatenated into SQL queries.

Database errors should also be hidden from users and logged securely on the server.

5.3 Secure Patient PDF Access

Patient documents should be stored outside the publicly accessible web root.

Every request for a document should be checked server-side to verify that the authenticated user has permission to access that particular document.

5.4 Improve PDF Password Security

Where document encryption is required, strong unique passwords should be used.

However, document passwords should not be treated as a replacement for proper application-level authorization.

5.5 Remove Sensitive PDF Metadata

Unnecessary metadata should be removed before documents are distributed.

Internal comments, usernames and operational information should not be embedded within documents accessible to external users.

5.6 Disable Directory Listing and Remove Backups

Directory listing should be disabled across the web server.

Legacy database backups should be removed from the web root immediately.

Backups should instead be stored in a dedicated, access-controlled backup environment that is not directly accessible through the website.

5.7 Protect Database Backups

Database backups should be encrypted and access should be restricted according to the principle of least privilege.

The organisation should also establish regular backup-security audits to identify accidentally exposed files.

6. Risk Summary

Finding	Severity	Recommended Priority
Username Enumeration	Medium	High

Finding	Severity	Recommended Priority
Authentication / SQL Injection Weakness	Critical	Immediate
Confidential PDF Access	High	Immediate
Weak PDF Password Protection	High	Immediate
Sensitive PDF Metadata	Medium	High
Exposed Legacy Backup Directory	Critical	Immediate
Staff and Shareholder Data Exposure	Critical	Immediate

Overall Risk: CRITICAL

The combination of authentication weaknesses, insufficient document protection, metadata disclosure and an exposed database backup creates a serious overall security risk.

7. Conclusion

The penetration-testing assessment demonstrated that several individual weaknesses could be combined to produce significant information exposure.

The investigation began with reconnaissance and authentication testing before progressing to document security and metadata analysis. The metadata contained a reference to the `/old` directory, which correlated with information identified during earlier reconnaissance.

The legacy directory was configured to allow directory listing and exposed a historical database backup. Analysis of the supplied database data showed that it contained staff salary information and shareholder ownership information.

The correlation between the `j.malik` metadata identifier and the Jameel Malik staff record further demonstrated how seemingly small pieces of information can be connected during a penetration test.

The most important remediation actions are to **secure the authentication mechanism, enforce server-side authorization for sensitive documents, remove sensitive metadata, disable directory listing, and remove database backups from publicly accessible web directories.**

All Critical and High severity findings should be addressed as a priority.

8. Final Statement

This assessment was conducted as part of a controlled cybersecurity educational exercise. The techniques and findings documented in this report are intended solely for authorized security testing and academic purposes.

Security testing must only be performed against systems where explicit authorization has been provided by the system owner.

Submitted by: Kemar Goulbourne

Cybersecurity Mentor: Waqas Karim, CCIE

Organisation: Networkwalks

Batch: B082 | Week 4 Capstone Project

Classification: Confidential